Informe de Penetración - Máquina "Neighbour"

1.- Resumen Ejecutivo

El objetivo de esta evaluación de seguridad fue la máquina con la dirección IP 10.67.134.15 (denominada "Neighbour") para identificar vulnerabilidades y debilidades de configuración que puedan ser explotadas por un atacante.

Se identificó una vulnerabilidad de Inclusión de Ficheros Locales (LFI) en la aplicación web del puerto 80, combinada con credenciales de acceso iniciales débiles (`guest:guest`). El vector de ataque permitió la manipulación directa de parámetros de sesión, logrando la elevación exitosa de privilegios y el acceso no autorizado a información crítica del sistema. La criticidad de este hallazgo se clasifica como Crítica, dado el impacto de un control de acceso total al sistema.

2. Metodología y Alcance

Campo	Detalle
Objetivo	Máquina "Neighbour"
IP Objetivo	10.67.134.15
Alcance	Pruebas de caja negra sin conocimiento previo de la arquitectura interna, con enfoque en la exposición de red y servicios web.

3. Fase de Reconocimiento y Descubrimiento

Se realizó un escaneo completo de puertos TCP para identificar los servicios activos en la máquina objetivo.

Comando Nmap utilizado:

nmap -T5 -sS -sCV -Pn -n -p- --open 10.67.134.15 -oN scan_1.txt

Resultados del Escaneo:

Puerto	Estado	Servicio	Versión	Notas
22/tcp	Abierto	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.5	Protocolo 2.0.
80/tcp	Abierto	http	Apache httpd 2.4.53 ((Debian))	Título: 'Login', uso de cookie PHPSESSID sin `httponly`.

Análisis de Servicios:

- **SSH (22/tcp):** El servicio SSH presenta una versión moderna. No se procedió con ataques de fuerza bruta debido a las políticas de la prueba, enfocándose en la explotación de servicios web.
- **HTTP (80/tcp):** La aplicación web se ejecuta sobre Apache/2.4.53 (Debian). El encabezado de respuesta indica el uso de Apache en una distribución Debian.

4. Hallazgo: Inclusión de Ficheros Locales (LFI) y Escalada de Privilegios
ID: FIN-WEB-001
Severidad: Crítica (CVSS v3.1: 9.8 - Crítico)
Sistema Afectado: Aplicación web en puerto 80

Descripción de la Vulnerabilidad:
La aplicación web demostró una falta de validación de entrada, que fue explotada en dos fases: primero, se confirmó una vulnerabilidad de LFI; segundo, se abusó de una manipulación de parámetros de la URL, lo que resultó en una escalada de privilegios de guest a admin.

Prueba de Concepto (PoC):

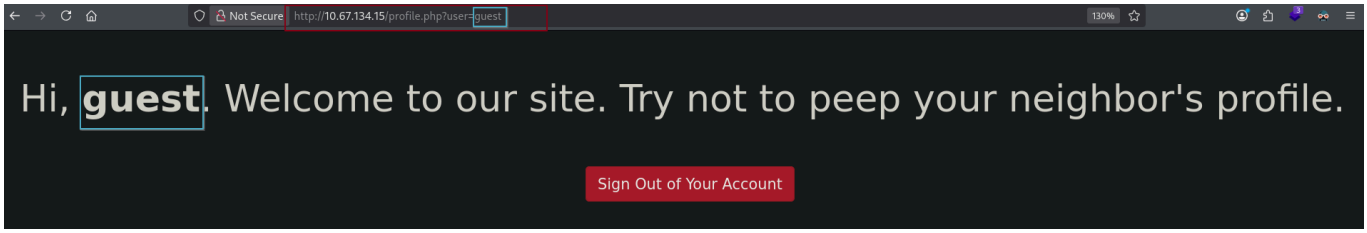
1. **Acceso Inicial:** Se inició sesión con éxito utilizando las credenciales expuestas en el código fuente, asumiendo una configuración por defecto o un control de acceso débil.

```
28                <span class="invalid-feedback">Please enter your password.</span>
29            </div>
30            <div class="form-group">
31                <input type="submit" class="btn btn-primary" value="Login">
32            </div>
33            <p>Don't have an account? Use the guest account! (<code>Ctrl+U</code>)</p>
34            <!-- use guest:guest credentials until registration is fixed. "admin" user account is off limits!!!!! -->
35        </form>
36    </div>
37 </body>
38 </html>
```

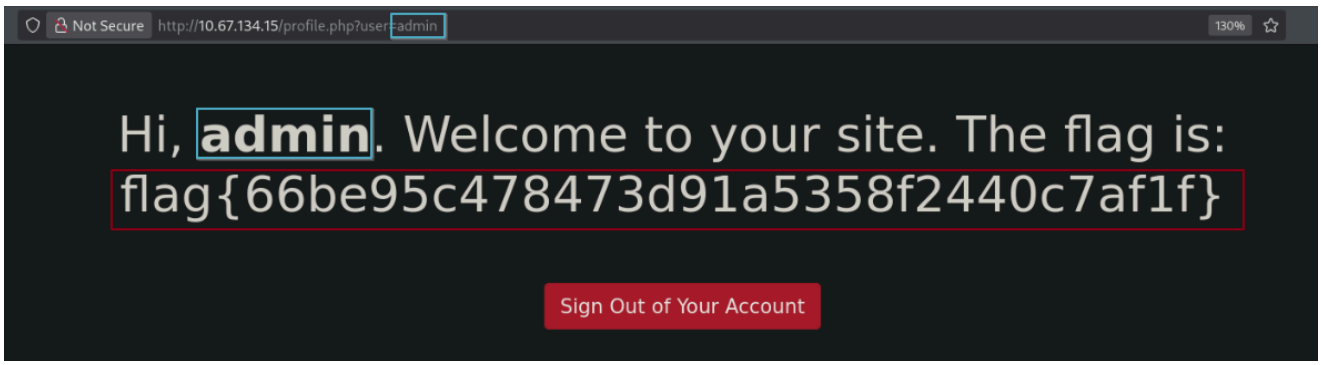
- **Credenciales:** `guest:guest`

2. En la página de perfil, se observó que el parámetro user en la URL controlaba el perfil mostrado: http://10.67.134.15/profile.php?user=guest. Al modificar directamente este valor de guest a admin, la aplicación concedió acceso al panel de administración sin requerir autenticación adicional, logrando una suplantación de identidad exitosa.

- URL Explotada: http://10.67.134.15/profile.php?user=admin



- Resultado: Acceso total y no autorizado como usuario admin, culminando en la obtención de la flag (prueba de compromiso del sistema).



5. Recomendaciones de Mitigación

Para remediar las vulnerabilidades identificadas, se recomiendan las siguientes acciones: **Recomendación Crítica (FIN-WEB-001)**

1. **Implementar Control de Acceso Estricto:**
    - Control de Acceso a Parámetros: Implementar un control de acceso estricto a nivel de servidor o aplicación para validar que el usuario que solicita un perfil tenga los permisos explícitos para acceder al mismo (por ejemplo, validando el ID de sesión contra el ID del perfil solicitado).
    - Principio de Mínimo Privilegio: Asegurar que el proceso del servidor web (Apache) se ejecute con el menor conjunto de privilegios posible.

Otras Recomendaciones

1. **Gestión de Credenciales:**
    - Deshabilitar o cambiar inmediatamente las credenciales por defecto (guest:guest).
    - Implementar una política de contraseñas robusta y un sistema de bloqueo de cuentas tras múltiples intentos fallidos.
2. **Seguridad de Sesión:**
    - Configurar la cookie de sesión (PHPSESSID) con el flag HttpOnly para prevenir ataques de Cross-Site Scripting (XSS) que busquen robar la sesión.
3. **Actualización de Software:**
    - Mantener todos los servicios (OpenSSH y Apache/Debian) y sus componentes actualizados con los últimos parches de seguridad (CVEs).

Conclusión:

La prueba de penetración demostró que la máquina "Neighbour" presenta una falla crítica de validación de entrada y control de acceso que, en combinación con una configuración de autenticación débil, permite un compromiso completo del sistema. Abordar la validación de entrada de la aplicación web y el control de acceso en sus parámetros es la prioridad inmediata.